

Propuesta de arquitectura de banca digital para entidad BP

Diseño Arquitectónico bajo modelo C4 sobre Azure

Ing. Víctor Hugo Muñoz

Documento de diseño | 25 de septiembre de 2026

1. Descripción del ejercicio

Usted ha sido contratado por una entidad llamada BP como arquitecto de soluciones para diseñar un sistema de banca por internet, en este sistema los usuarios podrán acceder al histórico de sus movimientos, realizar transferencias y pagos entre cuentas propias e interbancarias.

Toda la información referente al cliente se tomará de 2 sistemas, una plataforma Core que contiene información básica de cliente, movimientos, productos y un sistema independiente que complementa la información del cliente cuando los datos se requieren en detalle.

Debido a que la norma exige que los usuarios sean notificados sobre los movimientos realizados, el sistema utilizará sistemas externos o propios de envío de notificaciones, mínimo 2.

Este sistema contará con 2 aplicaciones en el Front, una SPA y una Aplicación móvil desarrollada en un Framework multiplataforma. (Mencione 2 opciones y justifique el porqué de su elección).

Ambas aplicaciones autenticaran a los usuarios mediante un servicio que usa el estándar OAuth2.0, para el cual no requiere implementar toda la lógica, ya que la compañía cuenta con un producto que puede ser configurado para este fin; sin embargo, debe dar recomendaciones sobre cuál es el mejor flujo de autenticación que se debería usar según el estándar.

Tenga en cuenta que el sistema de Onboarding para nuevos clientes en la aplicación móvil usa reconocimiento facial, por tanto, su arquitectura deberá considerarlo como parte del flujo de autorización y autenticación, a partir del Onboarding el nuevo usuario podrá ingresar al sistema mediante usuario y clave, huella o algún otro método especifique alguno de los anteriores dentro de su arquitectura, también puede recomendar herramientas de industria que realicen estas tareas y robustezca su aplicación.

El sistema utiliza una base de datos de auditoría que registra todas las acciones del cliente y cuenta con un mecanismo de persistencia de información para clientes frecuentes, para este caso proponga una alternativa basada en patrones de diseño que relacione los componentes que deberían interactuar para conseguir el objetivo.

Para obtener los datos del cliente el sistema pasa por una capa de integración compuesta por un api Gateway y consume los servicios necesarios de acuerdo con el tipo de transacción, inicialmente usted cuenta con 3 servicios principales, consulta de datos básicos, consulta de movimientos y transferencias que realiza llamados a servicios externos dependiendo del tipo, si considera que debería agregar más servicios para mejorar el rendimiento de su arquitectura o agregar más servicios para mejorar la repuesta de información a sus clientes, es libre de hacerlo.

Consideraciones.

Para este reto, mencione aquellos elementos normativos que considere importantes a tener en cuenta para entidades financieras, Ejemplo ley de datos personales, seguridad, etc.

Garantice en su arquitectura, alta disponibilidad (HA), tolerancia a fallos, recuperación ante desastres (DR), Seguridad y Monitoreo, Excelencia operativa y auto-healing. Si lo considera necesario, su arquitectura puede contener elementos de infraestructura en nube, Azure u AWS, garantice baja latencia, cuenta con presupuesto para esto.

En lo posible plantee una arquitectura desacoplada con elementos y reusables y cohesionados para otros componentes que puedan adicionarse en el futuro.

El modelo debe ser desarrollado bajo modelo c4 (Modelo de Contexto, Modelo de aplicación o contenedor y componentes), describa hasta el modelo de componentes, la infraestructura la puede modelar como usted lo considere usando la herramienta de su preferencia.

2. Resumen ejecutivo

Se propone un canal digital resiliente en Azure, con SPA y app móvil detrás de una capa perimetral protegida, servicios de dominio cohesivos e integración anticorrupción con el Core bancario y el sistema de detalle del cliente. El Core conserva la autoridad sobre cuentas, movimientos y pagos. Las operaciones se aceptan con una referencia idempotente y un estado explícito, y se concilian con el Core y las redes interbancarias.

La arquitectura usa comunicación síncrona para lecturas y validaciones que determinan la respuesta inmediata, y mensajería para efectos secundarios durables (auditoría y notificaciones). Una operación financiera nunca depende de que un email o push haya sido enviado. Cada transición crítica se registra con correlación.

2.1 Decisiones principales de arquitectura

Las decisiones priorizan la autoridad contable del Core, la protección de operaciones financieras, la disponibilidad del canal y un costo operativo proporcional a la carga que BP confirme.

Decisión	Criterio de diseño
Nube y ejecución	Azure como plataforma administrada; Container Apps como punto de partida. AKS se incorpora cuando la escala, el control de plataforma o las capacidades del equipo lo justifiquen. Azure Service Bus cubren persistencia operativa y mensajería.
Dimensionamiento	Capacidad y costo se calculan a partir de picos, concurrencia, tamaño y retención de mensajes, latencia de dependencias y SLA acordados.
Patrones	Saga se aplica al ciclo de transferencias con estado persistido; Cache-Aside se limita a lecturas permitidas. CQRS o Event Sourcing completos no se incorporan sin una necesidad medible. Timeout, circuit breaker y retry con idempotencia: definir límites de espera por dependencia y operación; abrir el circuito ante fallos o latencia persistentes y permitir sondeos controlados de recuperación; reintentar únicamente fallos transitorios, con intentos limitados, backoff exponencial y jitter, manteniendo la misma Idempotency-Key y persistiendo su hash y estado para deduplicar. Si el resultado de una transferencia queda incierto por timeout, consultar y conciliar su estado antes de reenviarla; nunca repetir débitos a ciegas.
Identidad	CIAM configurable con OIDC, Authorization Code + PKCE, MFA, passkeys y rotación de refresh tokens. La selección final depende de las capacidades contratadas y verificadas.
Onboarding	La prueba facial y de vida valida identidad durante el alta; en el acceso habitual, la biometría local desbloquea una credencial del dispositivo y no se transmite al banco.
Pagos	El Core conserva la Idempotencia.
Datos y auditoría	SQLServer por dominio conserva el estado transaccional. Para proyecciones de consulta con esquema flexible, evaluar Azure Cosmos DB si se priorizan baja latencia y distribución geográfica, o MongoDB si encaja mejor con el modelo documental y las capacidades operativas del equipo; elegir una sola alternativa según carga y requisitos, sin duplicar almacenes por defecto. La auditoría se mantiene append-only y su evidencia oficial se conserva en almacenamiento inmutable; Cosmos DB o MongoDB podrían servir proyecciones consultables, pero no sustituir ese archivo.

Decisión	Criterio de diseño
Resiliencia	Diseño multi-zona y recuperación regional activa-pasiva con objetivos iniciales sujetos al BIA, pruebas de restauración, runbooks y límites explícitos de auto-healing.
Vistas C4	C1 delimita actores y sistemas relacionados; C2 muestra contenedores y dependencias; C3 detalla componentes dentro de un contenedor; Infraestructura detalla protocolos y Cloud.

3. Alcance, actores y supuestos

Incluye onboarding digital con validación documental y prueba de vida, autenticación/autorización, consulta de productos y movimientos, pagos internos e interbancarios, auditoría, notificación multicanal, operación y recuperación. El Core existente posee cliente básico, productos, movimientos y contabilización; un sistema de perfil complementa atributos detallados. No se asume API/contrato, SLA, capacidad de idempotencia ni protocolo de esos legados: el adaptador debe validar esas capacidades y acordar contratos con sus propietarios.

Actor del sistema de banca digital: cliente nuevo o existente. Sistemas relacionados: IAM/CIAM existente, proveedor facial/KYC, Core, fuente independiente de perfil detallado y al menos dos rutas de notificación. La auditoría y el monitoreo son requisitos transversales de la solución, no actores adicionales del C1. La información biométrica se trata como dato de categoría especial: minimizar captura/retención y no guardar imágenes o plantillas biométricas en la app ni en logs.

4. C4

C1 - Contexto

El cliente nuevo o existente accede por los canales web y móvil al sistema de interés Banca Digital BP. Las jornadas anotadas son onboarding, autenticación, consulta, pago y notificación/auditoría. Se muestran por separado Core y perfil detallado, además de IAM/CIAM, KYC facial, aplicaciones críticas y dos rutas de notificación. La alineación BIAN es orientativa y no implica un despliegue por Service Domain.

C1 | CONTEXTO DEL SISTEMA · MODELO C4

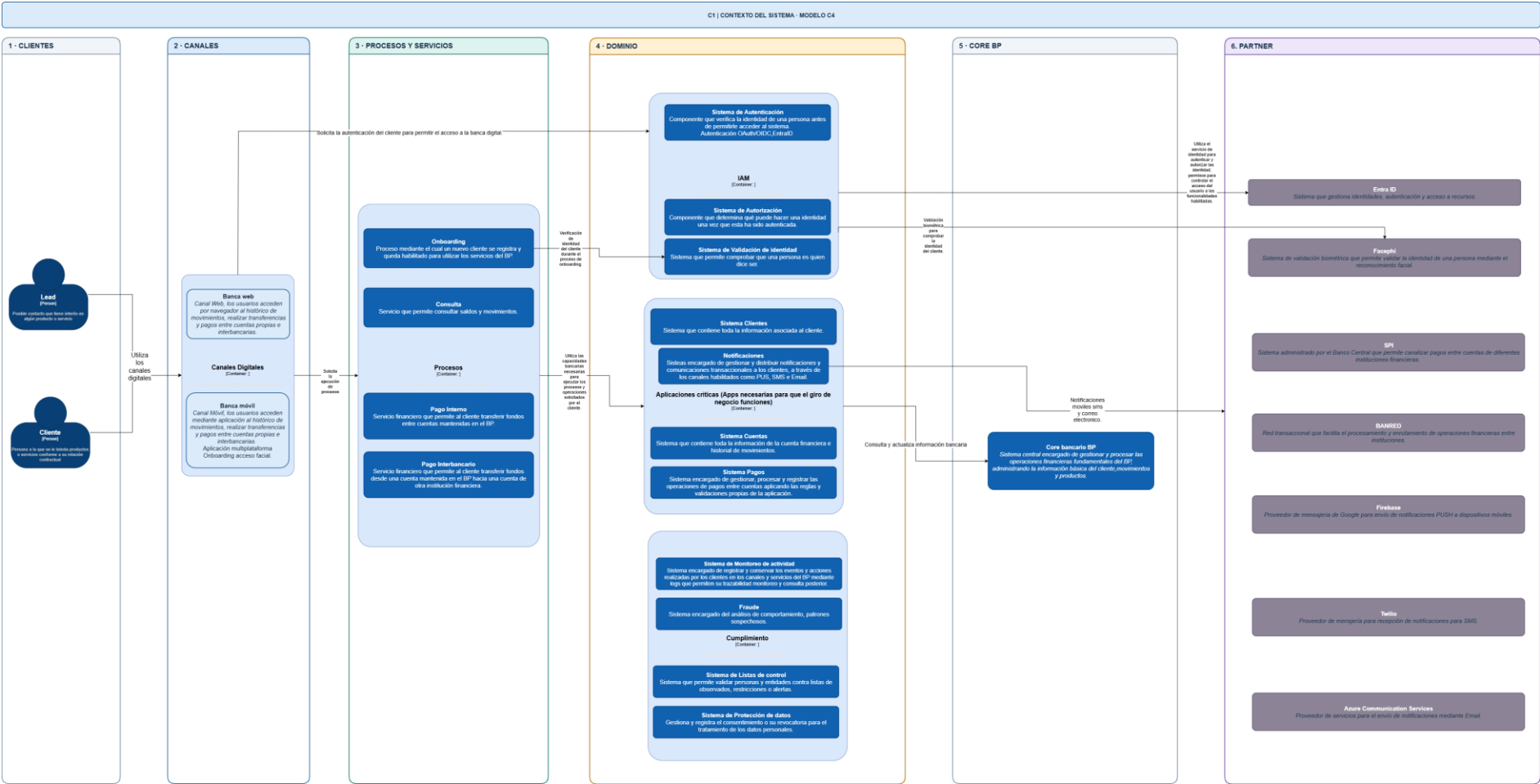


Figura 1. Contexto de banca digital BP, actores y sistemas externos.

C2 - Contenedores

El perímetro incluye Front Door/WAF, API Management y BFF web/móvil. Los contenedores incluyen perfil, onboarding, consulta de movimientos, posición consolidada, pagos, integración y notificaciones.

C2 | DIAGRAMA DE CONTENEDORES C4

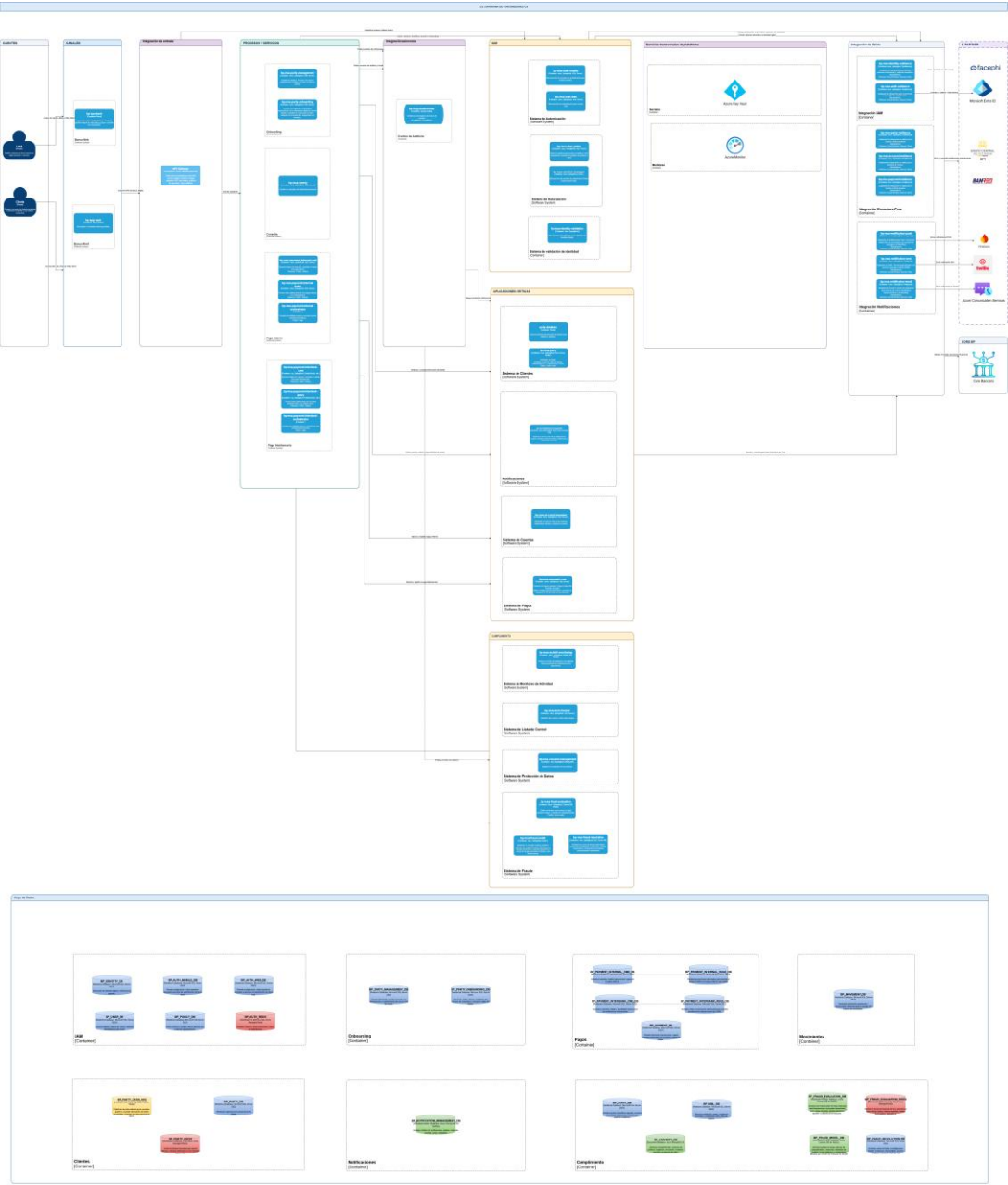


Figura 2. Contenedores, dependencias y flujos principales.

C3 - Componentes de transferencias

La descomposición de componentes cubre transferencias, consulta de movimientos, onboarding/acceso y notificaciones. Se detallan autorización por recurso, idempotencia y Saga; separación entre lectura proyectada y lectura autoritativa; ciclo de onboarding y CIAM; y deduplicación, fallback, reintentos y DLQ de notificaciones. La vista de despliegue Azure relaciona contenedores C2 con zonas, regiones y servicios administrados.

C3 | DIAGRAMA DE COMPONENTES C4

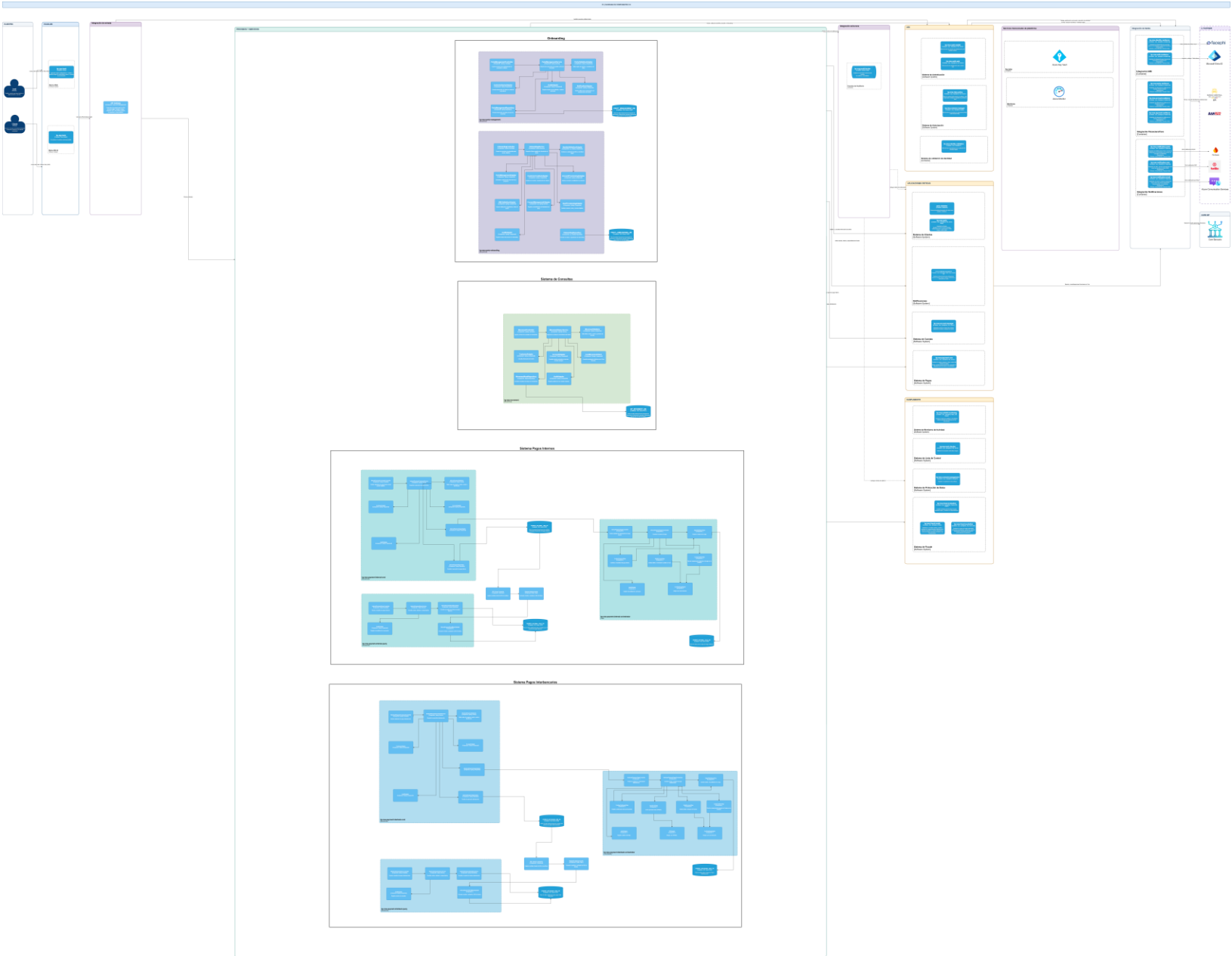


Figura 3. Componentes del flujo de transferencia.

Infraestructura

Es la capa Cloud que aloja y conecta los contenedores de la banca digital. Incluye Front Door y WAF para recibir y proteger el tráfico; API Management y cómputo para atender las solicitudes; SQLServer, Redis y Service Bus para persistencia, caché y mensajería; además de almacenamiento de auditoría, gestión de secretos, monitoreo y la región de recuperación ante desastres.

INFRAESTRUCTURA

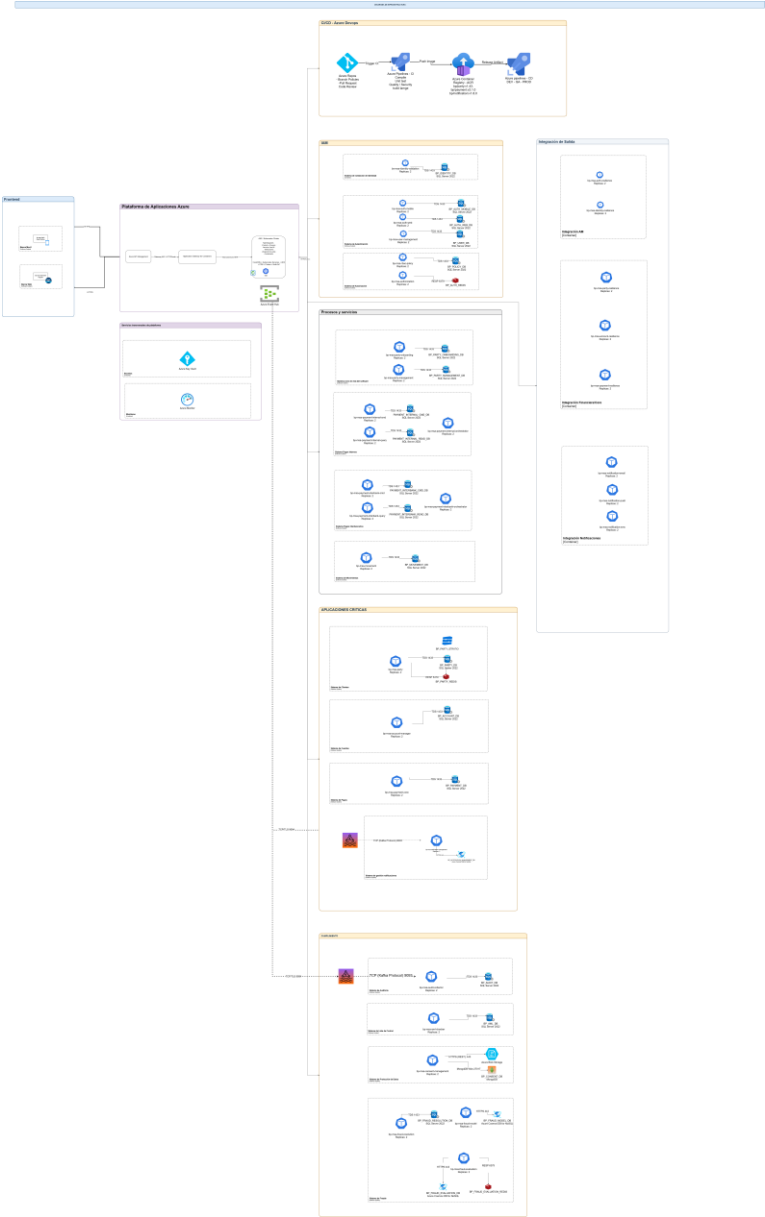


Figura 4. Infraestructura.

5. Flujos esenciales

Inicio de sesión

La SPA inicia Authorization Code + PKCE contra el proveedor OIDC y termina en un BFF que guarda tokens del lado servidor; cookie de sesión opaca `Secure`, `HttpOnly`, `SameSite`, protección CSRF y rotación. Alternativamente puede ser cliente público con PKCE y tokens solo en memoria, nunca en `localStorage`; BFF reduce exposición XSS, a cambio de mantener sesión servidor. En móvil el SDK oficial usa navegador del sistema, deep link verificado y PKCE S256. Se deshabilitan Implicit y Resource Owner Password Credentials. Access tokens breves y de audiencia mínima; refresh token rotation con detección de replay; step-up MFA para beneficiarios nuevos, dispositivo nuevo, cambio de credenciales y montos/riesgos altos.

La huella/Face ID local desbloquea una clave privada del dispositivo o un passkey (FIDO2/WebAuthn); la biometría nunca se envía al banco ni sustituye la autenticación del servidor. El dispositivo demuestra posesión criptográfica. Se ofrece fallback con contraseña + MFA y recuperación con verificación reforzada. Onboarding prueba identidad mediante documento + selfie con liveness y revisión de fraude; el proveedor entrega resultado/score y referencia, no una plantilla reutilizable. La decisión de alta requiere reglas de riesgo y revisión manual para casos ambiguos. Un enrolamiento aceptado vincula identidad bancaria y sujeto OIDC de forma atómica desde el punto de vista de negocio, con estados pendientes/reintento/rechazo auditables.

Consulta de movimientos

El BFF valida sesión y el servicio consulta proyección de movimientos o Core mediante adapter. Datos detallados se enriquecen desde Perfil solo si el caso los requiere. Paginación por cursor, ventana temporal y límites; caché opcional de catálogo/perfil no sensible. Una caída del Core produce degradación explícita (último dato con marca temporal si política lo permite, o error), nunca se presenta caché como saldo autoritativo.

Pagos

1. Canal envía orden, `Idempotency-Key` única, importe decimal con moneda, cuenta origen/destino y desafío step-up si aplica.
2. API valida JWT/scope, CSRF en BFF, esquema, límites de petición y cuota; servicio valida titularidad, estado, límites, beneficiario y riesgo con dato fresco.
3. Orquestador persiste `RECEIVED` y pasos con clave idempotente; aplica reserva/débito según contrato Core y procesa respuesta síncrona o callback. Estado final `POSTED`, `REJECTED` o `PENDING_RECONCILIATION` no se infiere por timeout.
4. La transacción de estado es atómica en la base del orquestador. Relay publica evento versionado a Service Bus; el consumidor escribe auditoría y genera aviso.
5. En timeout se consulta estado por referencia antes de reintentar. No se reenvía un débito ciegamente. Compensación solo procede cuando el contrato del Core/rail la soporta; reverso financiero no equivale a rollback de base distribuida.

Sagas para pagos interbancarios expresan pasos/compensaciones como máquina de estados persistida, con timeout, callback firmado, reconciliación de pendientes y proceso operativo. Si Core ofrece operación atómica/idempotente, delegar el movimiento contable allí es preferible a simular atomicidad con microservicios.

6. Persistencia y consistencia

- **Core:** única fuente contable para saldo/asiento; contrato de consulta y comando detrás de adaptadores separados.
- **SQLServer por servicio:** estado de onboarding, transferencias/orquestación, notificaciones y outbox, con esquema/credenciales aislados y transacciones ACID locales. No hay consultas cross-schema ni base compartida entre microservicios.
- **Proyecciones:** opcionales para historial/consulta, actualizadas por eventos y marcadas con fecha/versión de sincronización; no deciden si hay fondos disponibles.
- **Redis Cache-Aside:** catálogos y perfil de baja volatilidad con TTL/invalidación y cifrado/red privada. Excluir credenciales, secretos, OTP, PAN (si aplica), biometría, saldo autorizante e información que la política no permita.
- **Auditoría:** separar auditoría de negocio, logs de seguridad/IAM y telemetría operacional. Persistir actor pseudónimo, acción, recurso, resultado, timestamp UTC, correlation/trace ID, versión y motivo; filtrar tokens y PII. Evento append-only + exportación a almacenamiento con policy WORM, RBAC segregado, retención/borrado legal aprobados, hash chain/firma y evidencias de acceso. Kafka/broker no es el archivo legal de auditoría.
- **Patrones de acceso:** Repository para encapsular almacenamiento y Cache-Aside Decorator alrededor de lecturas idempotentes, con métricas de hit/miss y invalidación. Transactional Outbox para publicar sin dual-write. Evitar Event Sourcing total: conservar eventos de negocio necesarios para trazabilidad y replays acotados.

7. Seguridad y normativa

Controles: TLS externo e interno, cifrado at-rest con llaves administradas/rotadas, managed identities, Key Vault, segmentación privada, egress allowlist, WAF/bot/rate limit, DDoS, validación de entrada, CSP, protección CSRF, SAST/DAST/dependency scan, SBOM y firma de artefactos, hardening de imágenes, RBAC least privilege, PAM/JIT para operación, separación de funciones y alertas SOC. Token no es autorización completa: validar titularidad/ownership en cada recurso. Confirmación transaccional muestra importe/beneficiario y enlaza el desafío con los datos de la orden.

Marco Ecuador a evaluar con asesoría legal y Cumplimiento:

LOPD y RGLOPD: base de legitimación, transparencia, finalidad/minimización, derechos, seguridad, evaluación de impacto cuando corresponda, gestión de encargado, incidentes, retención/eliminación y transferencia internacional. La imagen facial/dato biométrico exige evaluación reforzada de necesidad, proporcionalidad, controles y contrato del proveedor. Aplicar normativa SPDP vigente de transferencias (incluida resolución 2026-0004-R) según rol y destino.

Código Orgánico Monetario y Financiero y normativa de Junta/Superintendencia de Bancos: sigilo/reserva financiera, seguridad de canales, gestión integral de riesgo operativo y tecnológico, continuidad/contingencia, incidentes, auditoría y proveedores críticos. Verificar versión/capítulo aplicable al tipo de entidad y fechas de vigencia.

Normas de riesgo operativo y seguridad/ciberseguridad de SB: matriz de riesgos, controles, continuidad, pruebas, proveedores y evidencia auditable. Diseñar mapeo de control y responsable, no afirmar certificación automática.

Prevención de lavado/financiamiento ilícito y KYC: controles de identidad y listas/monitoreo los determina Cumplimiento; onboarding integra interfaces aprobadas sin persistir copias innecesarias.

PCI DSS solo si el alcance procesa, almacena o transmite datos de tarjeta; no asumir que aplica a transferencias de cuenta. ISO 27001/27017/27018, NIST CSF y OWASP ASVS/MASVS son marcos de referencia, no leyes ecuatorianas.

8. Disponibilidad, DR y objetivos

Diseño inicial sujeto al BIA/SLAs del Core: disponibilidad objetivo 99.95% mensual para APIs de lectura, RTO ≤ 60 min y RPO ≤ 5 min para estados del canal; revisar si el negocio requiere objetivos más estrictos. Zonal redundancy para APIM, cómputo, base y broker; balanceo multi-zona, réplicas síncronas cuando el servicio lo permita, health/readiness probes, autoscaling, despliegue rolling/canary y auto-healing. Región secundaria emparejada con backup cifrado/geo-redundante y restauración probada; failover DNS/Front Door y runbooks. No declarar activo-activo hasta resolver consistencia, escritor único, idempotencia y conflicto entre regiones.

Resiliencia por dependencia: timeouts por presupuesto, circuit breaker, retry solo idempotente con backoff exponencial + jitter, bulkhead/concurrency limits, límites de cola, DLQ con redrive controlado, graceful degradation y reconciliation queue. Core/rail con cuota/capacidad pactada; semáforo y circuit breaker sin fallback a saldo cacheado. Pruebas de restauración/failover y ejercicios de caos acotados.

9. Observabilidad y excelencia operativa

OpenTelemetry para trazas, métricas y logs correlacionados; Azure Monitor/Application Insights, Log Analytics, Managed Prometheus/Grafana y alertas al SOC/operación. Métricas de negocio: pagos por estado, latencia Core/rail, idempotency hit, importe en conciliación, edad de DLQ, latencia/pérdida de notificación. SLO/SLI y error budgets; alertar sobre síntomas e impacto cliente. Logs estructurados sin bearer token, OTP, biometría ni datos bancarios innecesarios. Auditoría y telemetría tienen almacenes, acceso y retención distintos.

CI/CD con IaC (Bicep/Terraform), entornos segregados, aprobación y segregación de funciones, secrets fuera del pipeline, escaneo de supply chain, despliegue progresivo y rollback. Runbooks para Core down, rail timeout, cola bloqueada, región degradada, fuga de credenciales y failover. Auto-healing repara instancias y workers; no vuelve a ejecutar comandos financieros sin comprobar su resultado.

10. Costos y escalado

Estimados. Se considera una región primaria con AKS distribuido entre zonas de disponibilidad y una región secundaria en espera para recuperación ante desastres (DR). Los microservicios comparten clústeres AKS por ambiente y región; no se crea un clúster por microservicio. Como el enunciado no define usuarios concurrentes, transacciones por segundo, retención ni volúmenes de datos, el costo total debe cerrarse con esas métricas y la región Azure elegida.

Componente	Principales factores de costo	Criterio de escalado y control
AKS	Tarifa del nivel de administración Standard, máquinas virtuales de los nodos, discos y red. Los nodos de producción se cobran mientras están aprovisionados.	Mantener nodos en varias zonas y escalar el pool según CPU, memoria y demanda. Usar HPA y Cluster Autoscaler; dimensionar el DR en espera con capacidad mínima compatible con el RTO.
Front Door Premium y WAF	Cargo base, solicitudes y transferencia de datos hacia usuarios y origen. La tarifa pública consultada muestra USD 330/mes de cargo base para Premium; WAF y Private Link están incluidos en ese nivel. Para tráfico hacia Sudamérica se cobran solicitudes y transferencia según volumen. Precios de Front Door	
API Management	Nivel contratado, unidades de capacidad y regiones desplegadas. Las opciones de producción tienen costos mensuales por unidad; sumar regiones y unidades aumenta el costo. Costos de API Management	
PostgreSQL HA	Cómputo, almacenamiento, respaldos y réplica de recuperación. En HA zonal se facturan los recursos aprovisionados tanto para la réplica primaria como para la secundaria. Precios de PostgreSQL Flexible Server	
Azure Cache for Redis	Nivel, capacidad, fragmentos, réplicas y recursos de la región DR.	Dimensionar por conjunto de datos y conexiones; mantener fuera los saldos que autoricen operaciones.
Service Bus Premium	Unidades de mensajería por hora y, si se habilita geo-replicación de mensajes, volumen replicado.	Aumentar unidades según throughput y longitud/antigüedad de colas. Presupuestar aparte la capacidad de la región DR.
Blob Storage immutable	Capacidad almacenada, operaciones, redundancia y periodo de retención de auditoría.	Definir retención por clase de evidencia y usar políticas aprobadas por Cumplimiento.
Azure Monitor y Application Insights	Principalmente volumen de logs ingeridos y retenidos; también métricas, alertas y consultas.	Filtrar logs antes de enviarlos, muestrear trazas exitosas y conservar íntegros los eventos que la política exija. La ingesta y retención suelen ser los principales cargos de Monitor. Costos de Azure Monitor Logs
Key Vault y red	Operaciones de claves y secretos, endpoints privados, NAT, transferencia entre regiones y salida hacia Core/rieles.	Revisar cargos de conectividad y transferencia al medir el tráfico real entre regiones y sistemas externos.

11. ADR resumidos (decisión y razones)

ADR	Decisión	Razón 1	Razón 2	Alternativas consideradas
01 Nube	Azure administrado, componentes por necesidad	APIM, Entra, Key Vault y Monitor integran identidad/operación	Zonas, regiones y servicios administrados reducen tareas manuales	AWS equivalente; híbrido si Core/red lo exige
02 Web	Angular + BFF	BFF evita exponer refresh/access tokens al JS persistente	Angular favorece módulos, DI y gobierno de equipos enterprise	React/Next.js; SPA pública con tokens solo memoria
03 Móvil	React Native; Flutter como opción válida	Ecosistema TS y reutilización de conocimiento UI/API web	SDK nativo y biometría/passkeys mediante módulos con mantenimiento	Flutter ofrece UI consistente/rendimiento; Kotlin/Swift elevan costo doble
04 Identidad	OIDC Authorization Code + PKCE S256	Flujo actual para clientes públicos y redirecciones	PKCE protege código; navegador externo aísla credenciales en móvil	Implicit/RoPC descartados; BFF como cliente confidencial web
05 Integración	API Gateway + BFF + adapters/ACL	Gateway centraliza políticas perimetrales	BFF adapta contratos por canal; ACL desacopla formatos legados	Gateway directo a microservicios aumenta acoplamiento/exposición
06	Azure Service Bus,	Entrega durable, DLQ y	Menor carga operativa y	Kafka solo si

ADR	Decisión	Razón 1	Razón 2	Alternativas consideradas
Mensajería	idempotencia	colas para comandos/eventos de negocio	buena afinidad con Azure	orden/retención/replay/caudal al medido lo justifican
07 Datos	Core autoritativo; SQLServer por dominio	Preserva fuente contable y transacciones locales ACID	Evita base compartida y costos/consistencia de polyglot sin necesidad	Cosmos para acceso global/escala probada
08 Cache	Cache-Aside con allowlist	Reduce latencia/carga en catálogo y perfil	Invalidación/TTL explícitos limitan obsolescencia	No cachear información; nunca cache de saldo para autorizar
09 Auditoría	Eventos append-only + WORM	Resistencia a alteración y separación de permisos	Correlación reconstruye actor, acción y resultado sin guardar secretos	Solo logs técnicos es insuficiente; Event Sourcing completo excesivo
10 HA/DR	Multi-zona + región secundaria activa-pasiva	Zona cubre fallos locales con baja latencia	Activo-pasivo evita conflictos contables multi-región	Activo-activo solo con requisitos/consistencia y Core aptos
11 Biometría	Liveness/KYC proveedor + biometría local para passkey	Liveness ayuda contra suplantación en alta	Autenticación local evita transmitir biometría al backend	Face unlock del SO es UX, no factor remoto por sí mismo

Fuentes oficiales y estándares

- IETF, [RFC 9700 - OAuth 2.0 Security Best Current Practice](#).
- IETF, [RFC 8252 - OAuth 2.0 para aplicaciones nativas](#).
- SPDP Ecuador, [resoluciones y normativa](#), incluida normativa de transferencias/comunicaciones internacionales vigente.
- Superintendencia de Bancos, [Codificación de las Normas - Libro Uno](#), riesgo operativo y capítulos aplicables.
- Superintendencia de Bancos, [Normativa del sistema controlado](#).
- OWASP, [Application Security Verification Standard](#) y [Mobile Application Security](#).

Fecha de consulta normativa: 25 de septiembre de 2026. La lista es un mapa de análisis, no opinión legal ni declaración de conformidad.